Enterprise Security & Access Control Policy

Policy ID: SEC-POL-2026-09 | **Effective Date:** October 1, 2026 | **Classification:** Confidential Internal

1. Purpose and Scope

This policy defines mandatory requirements for user identity authentication, credential hygiene, role-based access control (RBAC), and hardware security compliance across all corporate systems, production clusters, and cloud environments. Compliance is mandatory for all full-time employees, contractors, and third-party vendors.

2. Identity, Credential & Password Hygiene Standards

All corporate identities must adhere to strict zero-trust credential rules:

Parameter	Mandatory Requirement	Enforcement Mechanism
Minimum Length	16 characters	Okta Identity Engine filter
Complexity	Upper, lower, digits, special characters	Automated regex check
Rotation Schedule	Mandatory every 90 days	Automated account lockout warning
MFA Requirement	FIDO2 WebAuthn Hardware Key or Biometrics	SMS/Voice call MFA prohibited
Lockout Threshold	5 consecutive failed attempts	30-minute lock + Security alert

3. Zero Trust Remote Work & Network Perimeter

Direct SSH or RDP exposure to the public Internet is strictly forbidden. All engineers and staff accessing internal networks must route through the Corporate WireGuard VPN mesh with split-tunneling disabled for internal CIDR ranges (10.0.0.0/8). Session lifetimes are capped at 8 hours, requiring automated re-authentication.

4. Data Classification & Protection Tiers

Tier	Classification	Handling & Storage Requirements
Tier 1	Public	No encryption required at rest. Freely sharable.
Tier 2	Internal	AES-256 encryption at rest. Internal staff access only.
Tier 3	Confidential	KMS Customer-Managed Keys (CMEK), audit logging required.
Tier 4	Restricted / PII	Field-level tokenization, strict RBAC, data masking on display.

5. Violation Penalties and Reporting

Suspected security compromises, lost hardware tokens, or anomalous access events must be reported to the Security Operations Center (SOC) at security-incident@enterprise.corp within 15 minutes of discovery. Willful

non-compliance is grounds for immediate credential revocation and disciplinary review.